

Lotus Funds

SRS Gap Analysis

Latest database schema and application evidence compared with the Phase 1 Software Requirements Specification

ASSESSMENT OUTCOME

Phase 1 is not yet ready for regulated production sign-off.

Core foundations exist, but several controls that determine who may publish research, who receives it, and how immutable delivery evidence is retained are incomplete or absent.

Source	Evidence reviewed
SRS	Lotusfunds SRS.pdf - 44 pages - supplied 05 Aug 2026
Database	5augplain.sql - PostgreSQL dump - 33 tables, 550 columns, 8 triggers
Application	C:\office\fintree - backend, frontend, API specification, tests
Validation	Backend tests 23/23; frontend tests 19/19; frontend build passed; OpenAPI 83 operations validated; backend build failed

Prepared: 05 Aug 2026 (Asia/Calcutta)

1. Executive summary

The implementation has substantial building blocks: detailed RA and broker onboarding, payment and subscription infrastructure, research call drafts and Errata, disclaimer snapshots, WhatsApp/Telegram delivery components, audit logs, and an API specification. These foundations reduce the amount of greenfield work remaining.

However, the current evidence does not demonstrate end-to-end compliance with the SRS. The highest-risk gap is authorization: the research-call creation route authenticates a bearer token and checks subscription features, but the inspected route/controller does not explicitly require the Research Analyst role, verified/active RA status, or unexpired SEBI registration before inserting a call. This must be corrected before production use.

P0	8	Production/compliance blockers
P1	8	Required for Phase 1 completeness
P2 / verify	6	Enhancements or operational proof

Recommended release decision

- Do not treat the current state as Phase 1 production-complete for regulated research distribution.
- Create a compliance release gate around the eight P0 items in this report.
- Retest authorization, immutability, recipient evidence, suspension, and performance calculations using adversarial integration tests.

What is already evidenced

- RA and broker registration data, document fields, approval/rejection states, and profile update requests.
- Subscription plan catalog, feature/limit controls, payment orders/transactions, Razorpay webhook events, and subscription lifecycle records.
- Research call Draft/Publish behavior, an originating-RA Errata chain, version history, stored published message text, and message-template snapshots.
- RA disclaimer history and per-call disclaimer text snapshots.
- WhatsApp participants/jobs/messages, Telegram users/jobs/messages, notification records, and general audit logging.
- Underlying Study input and searchable UI code, including a broad predefined list.

2. P0 blockers - resolve before regulated production

ID	Requirement	State	Evidence / gap	Required action
P0-01	Research publishing authorization	Partial	Creation and publish endpoints are authenticated, but no explicit RA-role, approved/active RA, or unexpired SEBI check was found in the inspected call route/controller.	Add a single server-side policy guard; deny by default; test CLIENT, BROKER, suspended RA, expired SEBI, and forged-plan cases.
P0-02	RBAC and actor model	Partial	users.role only permits RESEARCH_ANALYST, BROKER, CLIENT, SUPERADMIN, ADMIN, content/design, and guest are not represented consistently; company_users is a second user store with an unconstrained role.	Unify identity/roles or formally isolate stores; implement permission tables/policies and endpoint-level tests.
P0-03	Published-call immutability	Partial	Errata is implemented, but all 8 database triggers are timestamp-maintenance triggers. No database guard prevents UPDATE/DELETE of a published call; application PATCH paths exist for publish/exit.	Add database immutability rules with narrowly defined lifecycle transitions; revoke direct writes; retain append-only audit evidence.
P0-04	Audience targeting	Missing	No call-target, selected-broker, direct-subscriber, or all-subscriber relation exists in the 33-table schema. Delivery currently follows participant lists rather than a locked audience snapshot.	Model audience selection and immutable recipient snapshots before publishing; enforce broker scope and RA ownership.
P0-05	Delivery handshake and recipient audit	Missing	WhatsApp stores sent_at and jobs; Telegram has jobs/messages. No common per-recipient accepted/delivered/read/failed ledger with receiver-side timestamp was found.	Create channel-neutral delivery_attempt and delivery_receipt records, provider IDs, retry history, timestamps, and evidence retention.
P0-06	Research/non-research segregation	Missing	No content/article/blog/newsletter/version/edit-log tables or content API were found. Client blog pages are present but do not evidence a governed CMS.	Build a separate non-research content domain with classification, author/organization attribution, moderation boundaries, versioning, archive/unpublish, and recommendation-content validation.
P0-07	RA classification and broker assignment	Missing	The schema has RA and broker detail records, but no Independent/Broker-Hired/Organizational classification or RA-to-broker assignment relation.	Add classification, ownership, effective-dated assignments, publishing scope, and Phase 2 TPBRA isolation.
P0-08	Suspension cascade and performance freeze	Partial	User/subscription suspension fields exist. Evidence does not show an atomic cascade placing subscriptions on hold, notifying clients, blocking all publishing, and freezing performance as specified.	Implement one auditable suspension workflow and reinstate only after explicit clearance; add effective-date performance rules.

3. P1 gaps - required for Phase 1 completeness

ID	Gap and current evidence	Next action
P1-01 Partial	Mandatory call data Instrument, Buy/Sell, entry, target, stop-loss, horizon and study are present. HOLD is disallowed by the DB; lot size, stored/calculated risk-reward, and explicit ownership classification are absent.	Align SRS semantics and validations; decide whether HOLD belongs in Phase 1; calculate ratio deterministically.
P1-02 Partial	Disclaimer version identity RA disclaimer history and call text snapshots exist, but research_calls does not store disclaimer_history.id/version_number; broker/content disclaimer versioning is absent.	Reference an immutable disclaimer version ID on each publication and retain the rendered text snapshot.
P1-03 Partial	RA/broker/client subscriptions Generic user-plan subscriptions are strong, but no subscriber-to-RA or subscriber-to-broker relationship is modeled for routing and entitlement.	Add subscription subject/beneficiary relations and effective-dated entitlement snapshots.
P1-04 Partial	Central notifications A notification table and email templates exist, but notifications have no recipient user ID, delivery preferences, or channel delivery state. SRS reminders/content/announcement flows are not fully evidenced.	Create recipient-aware notification events, preferences, outbox/delivery state, retry, and expiry reminder scheduling.
P1-05 Partial	Performance correctness Latest Errata rows are selected and a calculation service exists, but no complete proof was found for SRS treatment of suspension freeze, public SEBI visibility, multi-target/lot-size logic, and benchmarked calculations.	Define signed calculation rules, golden datasets, versioned methodology, and audit-friendly result snapshots.
P1-06 Missing	White-label broker branding Broker legal/trade name exists, but no logo, color theme, contact snapshot, branding version, or immutable rendering evidence was found.	Add broker display name, branding assets/version, allowed fields, and publication-time branding snapshot.
P1-07 Partial	Terms and consent versioning Declaration booleans exist in ra_details, but no terms/policy document version, accepted_at, IP/device, or signature evidence table was found.	Store versioned legal documents and append-only acceptance records per actor.
P1-08 Partial	Production build and release hygiene Frontend build passes. Backend tsc fails because tests/config files are matched outside src rootDir. Test/debug routes and console logging remain in production paths.	Fix tsconfig include/exclude or rootDir, remove debug endpoints/logs, and make build/test/security checks mandatory in CI.

4. P2 enhancements and operational proof

Auto-publish and broker media tiers

Subscription tiers exist, but no scheduled publication time/job model or explicit Premium/Automated broker behavior was evidenced.

30-day cookies and login OTP

Password/reset OTP flows and JWT authentication exist. A consistent 30-day cookie/session policy and inactivity timeout enforcement were not evidenced; auth uses bearer headers.

Underlying Study personalization

The field and searchable options exist. Persisted frequently-used and last-five selections were not found.

Public/guest experience

CLIENT routes/pages exist, but guest educational content and SEBI-governed public performance access were not evidenced.

Mobile version management

No Android/iOS application or minimum-version/forced-upgrade service was found in the reviewed repository.

Broker/API future boundary

Broker onboarding exists, but an explicit current Non-API versus future API broker capability boundary was not found.

Non-functional requirements requiring environment evidence

These cannot be proven from a SQL dump and source tree alone. They need infrastructure configuration, monitoring, test results, and operating procedures.

Requirement	Evidence required for sign-off
Encryption at rest and in transit	Database/storage encryption settings, key management, TLS enforcement, secret rotation, field protection for PAN/bank/identity data.
Publishing latency under 2 seconds	Load test with agreed concurrency and percentile target; clarify whether the target ends at database commit or provider acceptance.
99.5% availability	Service-level indicators, monitoring, alerting, incident records, dependency targets, and maintenance-window policy.
Backup and disaster recovery	Automated backup schedule, retention, encryption, off-site copy, restore test, RPO/RTO, and documented recovery runbook.
Hacked RA / DDoS response	MFA, token/session revocation, anomaly and velocity limits, per-RA publish circuit breaker, WAF/rate controls, alerting, emergency suspension, and incident drill.

5. Database-specific findings

The database is strongest around registration, billing/subscriptions, payment traceability, research-call version data, and channel-specific delivery queues. It is weakest around relationship modeling and compliance-enforcement constraints.

Area	Observed	Assessment
Schema size	33 tables; 550 parsed columns	Material implementation, not an empty prototype
Triggers	8 triggers, all associated with updated_at maintenance	No evidenced published-call immutability guard
Research	research_calls, exits, modifications, Errata via parent/version fields, templates	Good version foundation; missing targeting, ownership class, lot size and risk-reward
Subscriptions	plans, features, limits, events, usage, payments, webhook events	Strong commercial foundation; missing RA/broker subscription subject relation
Delivery	WhatsApp and Telegram participants/jobs/messages	Channel-specific; missing common immutable recipient and receipt ledger
Content	No governed non-research content/version tables	Phase 1 functional gap
Identity	users plus company_users; inconsistent role representation	Authorization and lifecycle risk

Important schema mismatch

The SRS describes a hierarchy with Super Admin, Admin/Broker, RA subtypes, content/design roles, platform client, broker-only client, and guest. The primary users table constrains role to RESEARCH_ANALYST, BROKER, or CLIENT, while application middleware expects ADMIN and SUPERADMIN. This may be intentional because company_users is separate, but the separation is not expressed as one coherent authorization model in the reviewed evidence.

Important compliance mismatch

A disclaimer text snapshot is better than referencing only the current RA profile. For defensible traceability, each research call should additionally reference the exact disclaimer history row/version. Broker and non-research content disclaimers need the same versioned approach.

6. Application validation results

Check	Result	Meaning
Backend unit/integration tests	PASS - 4 files, 23 tests	Existing covered behavior passes; coverage is not broad enough for SRS sign-off.
Frontend tests	PASS - 2 files, 19 tests	Utility/template behavior passes.
Frontend production build	PASS with large-chunk warnings	Deployable bundle produced; RegistrationPage chunk is about 8.65 MB uncompressed.
Backend production build	FAIL	TS6059: test/config files are included outside rootDir=src.
OpenAPI validation	PASS - 83 operations	Specification parses and validates; it does not prove authorization or runtime behavior.

Security observations from inspected routes

- A global rate limiter and Helmet are configured, which is useful baseline hardening.
- The research-call route does not show an explicit role/status/SEBI-expiry guard before create or publish.
- The authentication middleware verifies JWT signature and extracts claims, but does not consult user status or user_sessions for revocation/inactivity on each request.
- A broker list route and broker registration route are exposed without authentication in the inspected router; confirm whether this exposure is intentional and appropriately data-minimized.
- A test endpoint remains inside both admin and research routers.

7. Recommended implementation sequence

Gate 1 - Identity and publishing control

Unify role policy; add verified/active/SEBI-expiry guard; session revocation and inactivity; publish velocity/circuit breaker; fix backend build.

Gate 2 - Immutable research record

Lock published calls at DB and service layers; formalize permitted lifecycle transitions; reference disclaimer version ID; complete required call fields.

Gate 3 - Audience and delivery evidence

Create targeting/recipient snapshots, RA-broker assignments, subscriber subject relations, delivery attempts/receipts, and provider timestamps.

Gate 4 - Suspension and performance

Atomic suspension cascade, client notification, performance freeze, signed calculation rules, Errata test matrices, and public visibility controls.

Gate 5 - Non-research and white label

Separate content CMS, attribution/versioning, content safety rules, broker branding snapshots, announcements and recipient-aware notifications.

Gate 6 - Operational readiness

Load/latency test, encrypted storage evidence, backup restore drill, monitoring/SLOs, security test, incident response drill, and compliance acceptance.

Definition of done for Phase 1

- Every SRS requirement has an owner, acceptance criteria, automated or manual evidence, and a final status.
- Negative authorization tests prove that every non-RA or ineligible RA cannot publish or issue Errata.
- A published call, its disclaimer version, selected audience, recipient list, rendered message, timestamps, and delivery outcomes can be reconstructed without relying on mutable profile data.
- Suspension immediately blocks publishing/distribution and produces auditable subscription, notification, and performance effects.
- Production builds are repeatable and all required tests, backup restore, load, security, and monitoring gates pass.

Appendix A - SRS coverage snapshot

Requirement area	Status	Basis
Governance roles	Partial	Admin middleware and separate company users exist; coherent full hierarchy not evidenced.
RA onboarding	Evidenced	Detailed RA documents, dates, declarations, approval and update request data.
Broker onboarding	Evidenced	Detailed legal/compliance/document fields and lifecycle status.
Research call Draft/Publish	Evidenced	Draft and publish paths exist.
Only eligible RA may publish	Partial	Subscription checks exist; explicit role/verification/expiry guard not evidenced.
Errata	Evidenced	Originating-RA ownership, version chain and reason are implemented.
Published immutability	Partial	Application convention exists; DB-level protection not evidenced.
Call targeting	Missing	No selected audience or immutable recipient snapshot model.
Broker read-only scope	Partial	UI/routes exist; complete server-side object authorization not demonstrated.
White label	Missing	No governed branding/version snapshot model.
Non-research CMS	Missing	No content/version domain evidenced.
Disclaimer versioning	Partial	RA history and call snapshot exist; exact version ID and other actor/content scope missing.
Subscription management	Evidenced	Strong generic plan/payment/lifecycle foundation.
RA/broker-specific entitlement	Missing	No subscription subject/beneficiary relationship.
Notifications	Partial	Table and channel/email components exist; recipient-centric orchestration incomplete.
Audit	Partial	General audit table/logger exists; access/distribution and immutable evidence incomplete.
Suspension	Partial	Status/reason fields exist; complete cascade and performance freeze not evidenced.
Performance	Partial	Calculation service exists; regulatory/freeze/benchmark evidence incomplete.
Underlying Study	Partial	Input/search list exists; frequency/last-five personalization missing.
Security/availability/NFR	Verify	Requires infrastructure and operational evidence.

Assessment limitation

This is a point-in-time technical evidence review of the supplied SRS, SQL dump, and repository. It did not connect to a live database, inspect cloud/network configuration, execute end-to-end channel delivery, perform penetration testing, or provide legal interpretation. Items marked Verify require separate operational evidence.